



Tu App ya Corre en AWS ... pero ¿Realmente es Segura?

Roberto Flores Segundo

Líder del AWS User Group Playa Vicente

TRACK

Track: Security & Compliance
| Nivel 100

SALA

Virtual

HORA

12:00 p.m. – 12:40 p.m. CST





SOBRE MÍ

Roberto Flores Segundo

Líder del AWS User Group Playa Vicente

«La vida no suele ser lineal.»

- AWS Certified Cloud Practitioner & ISO/IEC 27001:2022 Lead Auditor.
- Ex Becario AWS All Builders Welcome Grant (re:Invent Las Vegas) y graduado AWS re/Start.
- Comparto seguridad en la nube desde la práctica: qué construí, qué se rompió y qué aprendí.

[in/roberto-flores](#) · github.com/Siegfried-FS · [@robertoflores](#)

AGENDA

Lo que veremos hoy

1. El Espejismo de «Ya funciona en producción»
2. Los 4 Puntos Ciegos (IAM, Red, S3/STS y CloudTrail)
3. Demostración en Vivo: Ataque, Mitigación y Forense
4. Checklist del Builder, Gobernanza a \$0 USD y Q&A

● DEMO EN VIVO

Flujo de mitigación en vivo:

- Acceso Anónimo a S3: Bloqueo inmediato HTTP 403 Forbidden por BPA.
- Delegación con AWS STS: Generación de token SigV4 temporal y descarga autorizada.
- Modificación de Rol IAM: Cambio de permisos en caliente sobre la EC2 en vivo.
- Auditoría Forense: Localización inmediata de los eventos y la IP origen en CloudTrail.



1

El Espejismo de «Ya Funciona en Producción»

Seguir un tutorial te da una app que corre, pero no necesariamente una arquitectura protegida.



Punto Ciego 1: De Llaves Estáticas a IAM Roles

El error: Incrustar access keys (AKIA...) en archivos .env, código o scripts dentro del servidor.

El peligro: Si comprometen la instancia o se filtra un commit, la llave queda expuesta 24/7.

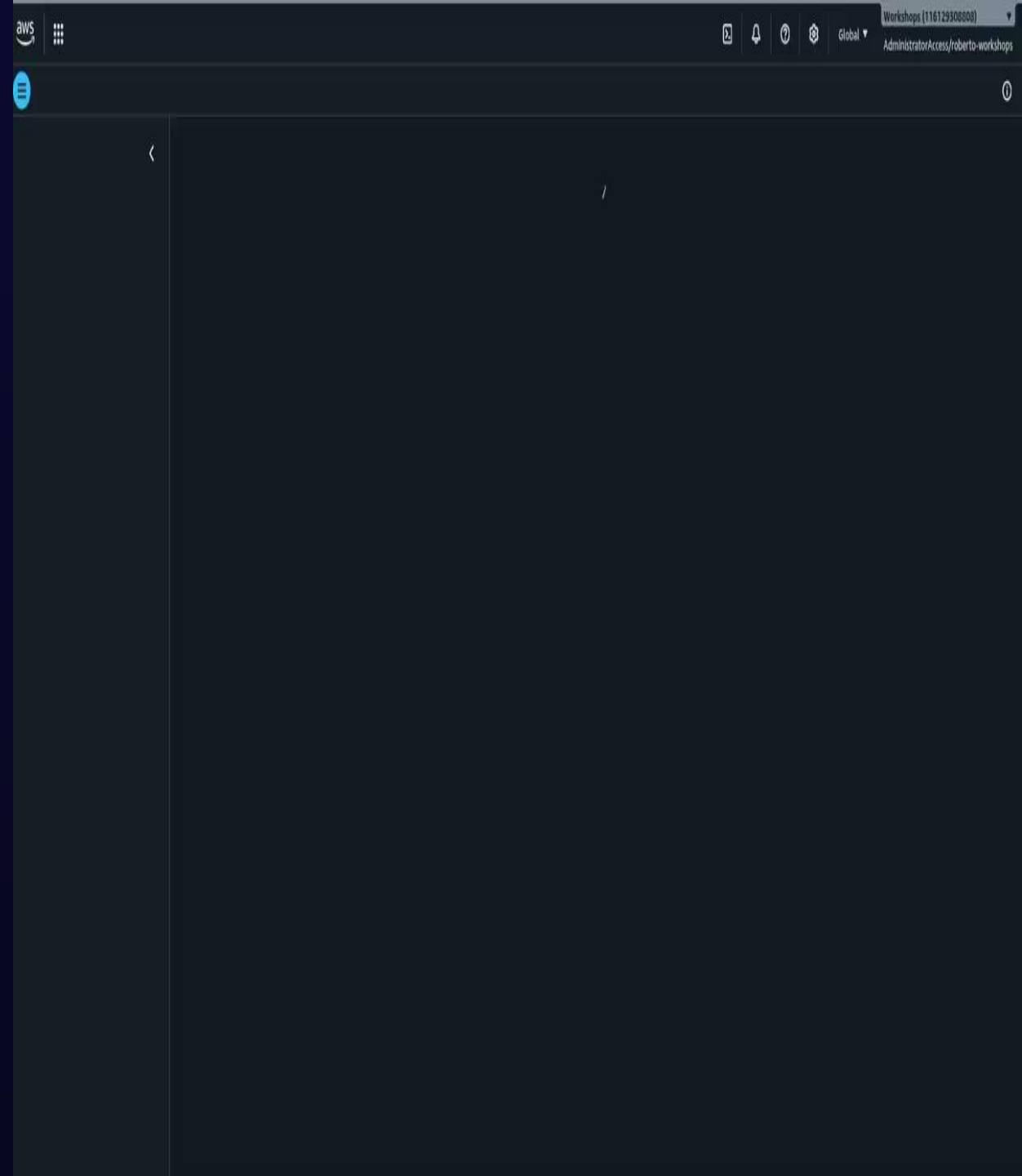
La solución nativa: Asignar un IAM Instance Profile (Rol de IAM) a la instancia EC2.

Menor Privilegio: Conceder solo la acción estricta (s3:PutObject) en el prefijo exacto (galeria/.*).

Lección real: Las llaves fijas son dejar la llave puesta en la chapa; los roles entregan credenciales temporales que rotan solas.

Política IAM de Menor Privilegio

Inspección del rol EC2PhotoWallRole en la consola oficial. Sin permisos globales de administración; únicamente s3:PutObject sobre el bucket de la sesión. Acciones destructivas retornan HTTP 403 AccessDenied.

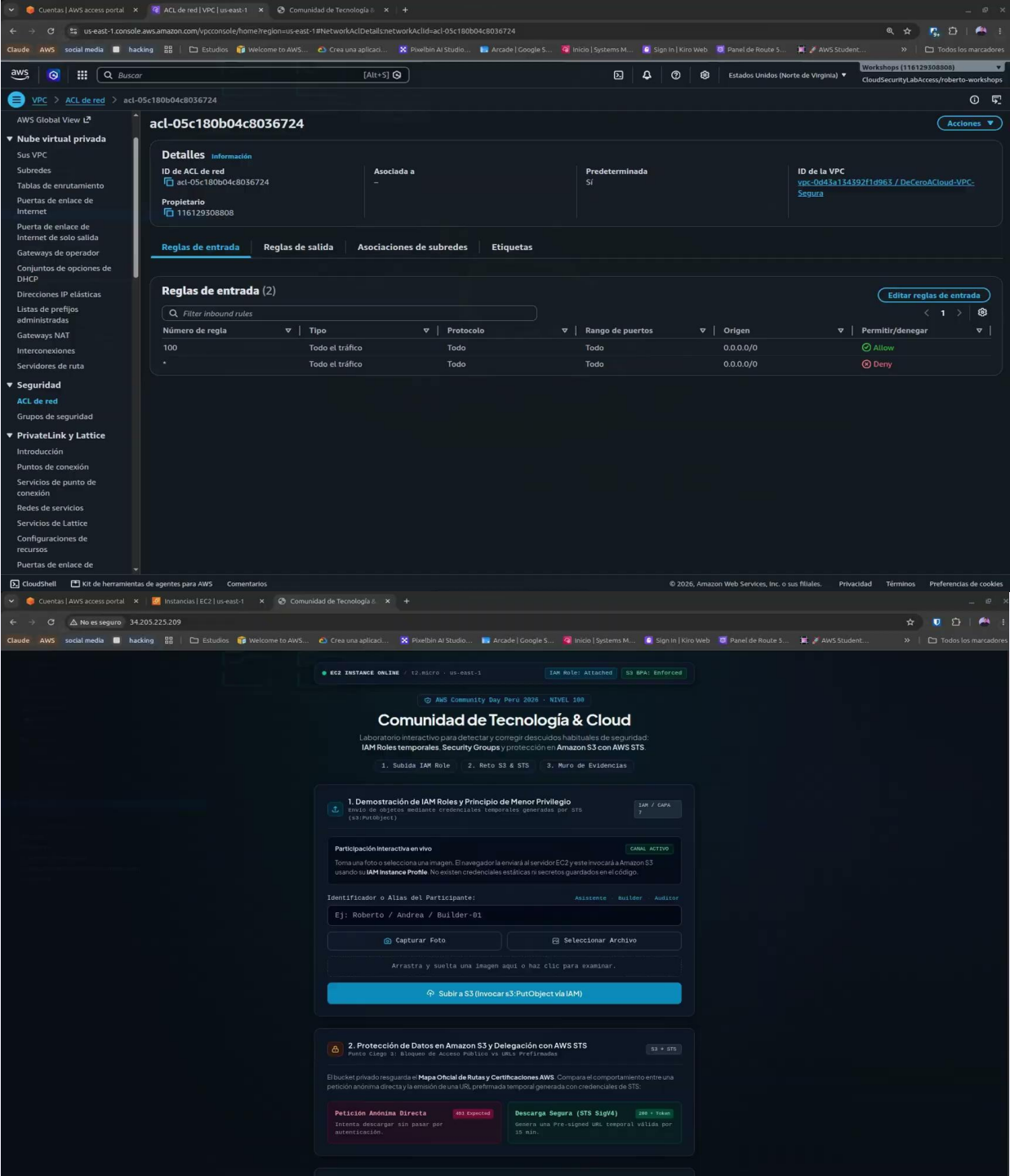


Punto Ciego 2: ¿Quién Controla el Tráfico?

- El error: Abrir puertos de administración (SSH 22, RDP 3389) o bases de datos a 0.0.0.0/0.
- El peligro: Escaneos masivos de bots y ataques automatizados en cuestión de minutos.
- Security Groups (Stateful): Filtran a nivel de interfaz de red (ENI) y solo soportan reglas de ALLOW.
- Network ACLs (Stateless): Filtran a nivel de subred y permiten reglas explícitas de DENY.
- Alternativa a \$0 USD: Sustituir SSH público por AWS Systems Manager Session Manager.

Título de Evidencia 2: Bloqueo Perimetral con NACL y Security Group

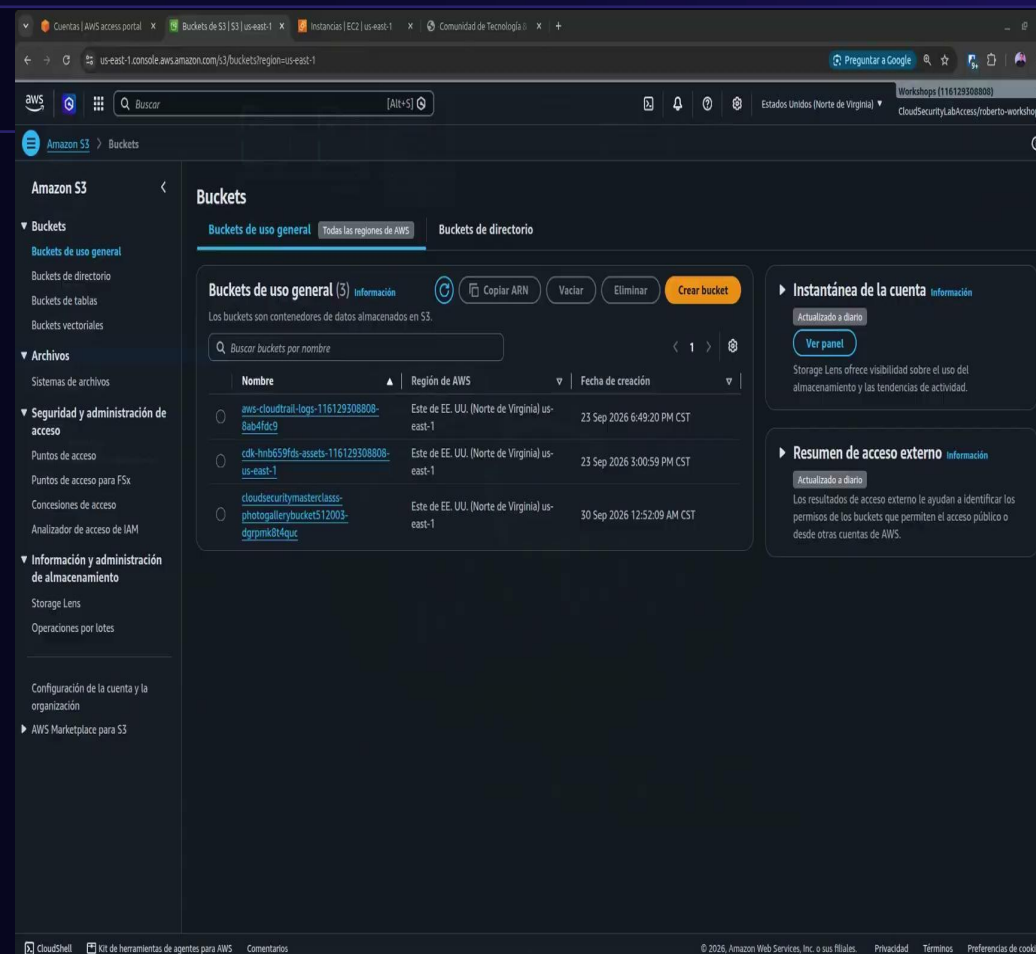
Configuración de la regla 50 DENY en la Network ACL para bloquear una IP atacante específica. A diferencia de un Security Group, la NACL descarta el tráfico perimetralmente antes de que consuma recursos en la instancia.



Evidencia 3: Descarga Segura con URLs Prefirmadas

● ● ● Demostración de Descarga con STS SigV4

- Petición Anónima Directa: Amazon S3 responde HTTP 403 Forbidden gracias a Block Public Access.
- Delegación Segura con AWS STS: La instancia EC2 solicita un token temporal firmado con SigV4 y emite una URL prefirmada válida por 15 minutos (900 s).
- El bucket se mantiene 100% PRIVADO en todo momento.



Punto Ciego 4: Trazabilidad Forense con CloudTrail

01

Event History a Costo Cero (\$0 USD)

(Últimos 90 días de llamadas de administración del plano de gestión incluidos gratis).

02

¿Quién lo hizo?

(Identidad IAM, rol asumido, ARN y tipo de credencial).

03

¿Desde dónde?

(Dirección IP pública de origen y User-Agent del cliente).

04

Inmutabilidad y Cumplimiento

(Registro cronológico forense para auditorías de seguridad, SOC 2 e ISO 27001).

Evidencia 4: Trazabilidad Forense en CloudTrail

Evento: RevokeSecurityGroupIngress

Consulta forense en CloudTrail

Manager event vs Data Event

Cuentas | AWS access portal

Historial de eventos | CloudTrail

us-east-1.console.aws.amazon.com/cloudtrailv2/home?region=us-east-1#/events

Claude AWS social media hacking Estudios Welcome to AWS... Crea una aplicac... PixelBin AI Studio... Arcade | Google S... Inicio | Systems M... Sign In | Kiro Web Panel de Route S... AWS Student... Todos los marcadores

aws

Buscar

[Alt+S]

Estados Unidos (Norte de Virginia)

Workshops (11612930800)

CloudSecurityLabAccess/roberto-workshops

CloudTrail

Historial de eventos

Panel

Cobertura de eventos de datos

Historial de eventos

Insights

Registros de seguimiento

Lago

Paneles

Consulta

Almacenes de datos de eventos

Integraciones

Configuración

Precios

Documentación

Foros

Preguntas frecuentes

La característica AWS CloudTrail Lake dejará de estar disponible para nuevos clientes a partir del 31 de mayo de 2026. Para obtener funcionalidades similares a las de la característica AWS CloudTrail Lake, explore Amazon CloudWatch. Más información

Historial de eventos (50+) Información

El historial de eventos muestra los últimos 90 días de eventos de administración.

Descargar eventos

Consulta en Lake

Crear tabla de Athena

Atributos de búsqueda

Nombre del evento

Q Escribir un nombre de evento

Filtrar por fecha y hora

Borrar filtro

1 2

☐	Nombre del evento	Hora del evento	Nombre de usuario	Origen del evento	Tipo de recurso	Nombre del recurso
☐	LookupEvents	septiembre 30, 2026, 01:16:53 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:16:52 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:16:17 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:16:17 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:16:17 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:16:17 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:16:14 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:16:13 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:16:02 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:15:43 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:15:43 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	LookupEvents	septiembre 30, 2026, 01:15:43 [...]	roberto-workshops	cloudtrail.amazonaws.com	-	-
☐	DescribeConfiguratio...	septiembre 30, 2026, 01:15:43 [...]	roberto-workshops	config.amazonaws.com	-	-
☐	CatTrailEvent...	septiembre 30, 2026, 01:15:43 [...]	roberto-workshops	cloudtrail.amazonaws.com	AWS-CloudTrail-Trail	arn:aws:cloudtrail:us-east-1...

Comparar 0 / 5 eventos seleccionados

CloudShell

Kit de herramientas de agentes para AWS

Comentarios

© 2026, Amazon Web Services, Inc. o sus filiales.

Privacidad

Términos

Preferencias de cookies

Checklist de Seguridad del Builder



Cero credenciales estáticas (AKIA...) en código o servidores; usar IAM Instance Profiles.



Security Groups restringidos (sin 0.0.0.0/0 en SSH, RDP o bases de datos).



Amazon S3 Block Public Access (BPA) forzado al 100% en bucket y cuenta.



URLs prefiradas con vigencia menor a 15 minutos para acceso a datos sensibles.



limpieza y destrucción con cdk destroy para garantizar \$0 USD de costo residual.



En la seguridad como en la ciencia, no existe la magia: las vulnerabilidades de ayer son los aprendizajes de hoy. Ningún sistema es perfecto, pero avanzamos cada vez que compartimos el conocimiento y no dejamos a nadie atrás.

Roberto Flores Segundo

Inspirado en la filosofía de Nikola Tesla (Record of Ragnarok)

Recursos & Lectura Red Team

Artículo publicado en AWS Builder Center y documentación oficial de referencia



Artículo: El puzzle de AWS (Parte 1: El ataque)

builder.aws.com/content/3JiEBMZHTlgwqUgzt2wAQXAXSjT



AWS Identity and Access Management (IAM)

docs.aws.amazon.com/iam/



Amazon S3 Security Best Practices (Block Public Access)

docs.aws.amazon.com/AmazonS3/latest/userguide/security-best-practices.html



SLIDES Y CÓDIGO

GitHub



¿Preguntas?



¡Gracias!

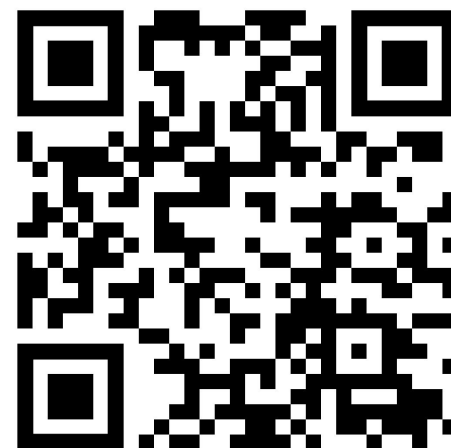
Roberto Flores Segundo

Líder del AWS User Group Playa Vicente

[in/roberto-flores](#)

[github.com/Siegfried-FS](#)

[@robertoflores](#)



ESCANEA Y CONECTEMOS



Comparte tu experiencia

Sube tus fotos del día y etiqueta a la comunidad

 **Instagram** @aws.community.day.peru

 **LinkedIn** AWS Community Day Perú

 **TikTok** @aws.community.day.peru

 **X** @AWS_ComDay_Peru

 awscommunityday.pe